

1. DATOS PERSONALES EXPUESTOS — VALVANERA PINILLA

1.1 Credenciales de mi personaje

Campo	Dato
Email	funcionario4guarroman@fpcheste.com
Contraseña	Dobby2510Hufflepuff

1.2 Datos personales deducibles de mi contraseña

Mi propia contraseña expone información personal sensible que cualquier atacante con acceso al hash o al texto plano podría explotar:

- **Dobby** → Afición por Harry Potter (personaje Dobby, el elfo doméstico)
- **2510** → Fecha probable: 25 de octubre (posible cumpleaños, aniversario o fecha significativa)
- **Hufflepuff** → Casa de Hogwarts a la que pertenezco o con la que me identifico
- **Patrón detectado:** NombreFandom + FechaNumérica + CasaHogwarts

1.3 Datos expuestos en correos recibidos

A través de los correos dirigidos específicamente a mí, otros compañeros han revelado lo siguiente sobre mi persona:

- **Apodo:** "Valva" (usado por Fermín en correo del photocall)
- **Aficiones:** Cosplay (Fermín escribe: *"sé que tu cosplay es lo más"*) y temática Harry Potter / friki (Merche pide adornos *"potterhead"* para el cumpleaños de su hija Paula)
- **Mascota:** Posible mascota llamada Dobby o disfraz de Dobby (Fermín dice: *"si te animas a venir con Dobby también"*)
- **Círculo social:** Compañeros confían en mí para eventos personales (photocall de cumpleaños, adornos para fiestas, streaming de Twitch)
- **Afición a videojuegos/streaming:** Invitada por Yaiza a su stream de Twitch (canal *"yaizaxxx"*)

2. DATOS DE COMPAÑEROS DETECTADOS EN MIS 9 CORREOS

A continuación se detalla toda la información de terceros extraída **exclusivamente** de los correos recibidos en mi buzón. Esta información representa un riesgo porque está distribuida sin cifrar y accesible para cualquier persona que comprometa mi cuenta.

2.1 Tabla de identidades expuestas

Remitente	Nombre real	Datos personales expuestos en el correo
funcionario2guarroman@	Trinidad Molina (Trini)	Gestiona pedidos de papelería del ayuntamiento
casaculturaguarroman@	Fermín Valverde	Tiene una perra llamada Lola , adoptada en 2021 , cumple 3 años en abril 2024. Toca la trompeta. Monta photocalls.
funcionario7guarroman@	Antolín	Pareja: Chiqui . Confiesa reutilizar la misma contraseña para todo.
funcionario5guarroman@	Braulio	Nacido en 1964 . Celebra 60 cumpleaños en El Roble (sábado 16, 21:00h).
funcionario6guarroman@	Merche	Hija: Paula , cumple 15 años el 9 del 9 (9 de septiembre). Mascota: Chelo (perro, " <i>bichón</i> "). Pide adornos <i>potterhead</i> .
alcalde.guarroman@	Baltasar Cañete Huertas	Alcalde. Mascota: perro Capitán (lo lleva a la Feria del Ganado). Convoca pleno ordinario el jueves 13 febrero 2025, 11:00h, salón noble . Confirmar asistencia a Rocío.
funcionario10guarroman@	Yaiza	Cumpleaños: 12 de diciembre (cumple 28). Pareja: Adrián . Mascota: conejo Ziggy (aparece en cámara). Canal de Twitch: <i>yaizaxxx</i> .

2.2 Relaciones personales y patrones detectados

- **Fermín ↔ Valvanera**: Confianza para temas frikis y photocalls. Conoce mi apodo ("Valva") y mi afición al cosplay.
- **Merche ↔ Valvanera**: Sabe que soy *potterhead* y confía en mí para decoración temática de cumpleaños.
- **Yaiza ↔ Valvanera**: Relación de confianza para eventos sociales digitales (streaming en Twitch).
- **Antolín ↔ Todo el ayuntamiento**: Expuso la contraseña WiFi sin restricción. Es un eslabón débil.
- **Braulio ↔ Todo el ayuntamiento**: Invitación masiva a su cumpleaños. Revela edad y restaurante habitual.

3. CONTRASEÑAS EN CLARO Y CREDENCIALES EXPUESTAS

3.1 CRÍTICO Contraseña WiFi corporativa en texto plano

Remitente: funcionario7guarroman@ (Antolín)

Fecha: 02/04/2024

Asunto: Wifi del ayuntamiento ha cambiado

Contenido literal del correo:

"Compañeros, nueva contraseña del wifi: ea7xyzchiqui1995 (sí, la misma que uso para todo — soy incorregible con esto, ya me lo dice Chiqui cuando trino). Antolín."

Análisis de la contraseña expuesta:

Componente	Significado probable
ea7xyz	Sufijo aleatorio o prefijo corporativo
chiqui	Nombre/apodo de su pareja
1995	Año probable de nacimiento de Chiqui o de Antolín

Gravedad: CRÍTICA

- La contraseña fue enviada a **toda la organización** (múltiples destinatarios).
- Cualquier persona con acceso a este correo (presente o futuro) conoce la WiFi corporativa.
- El remitente **confiesa explícitamente** que reutiliza esta misma contraseña en todos sus servicios personales.
- Esto habilita **credential stuffing**: un atacante puede probar ea7xyzchiqui1995 en el email de Antolín, sus redes sociales, VPN, NAS o cualquier otro servicio.

3.2 ALTA Confesión de reutilización de contraseñas

Antolín admite por escrito: "*la misma que uso para todo soy incorregible con esto*". Esta declaración confirma:

- Inexistencia de política de contraseñas en la organización.
- Hábito de reutilización de credenciales como práctica común.
- Cualquier filtración futura de Antolín compromete **todos** sus accesos.

4. PATRONES DE CONTRASEÑAS DETECTADOS EN GUARROMÁN

Analizando las contraseñas de mis compañeros (proporcionadas por el profesor para este ejercicio), identifico los siguientes patrones sistemáticos que un atacante podría explotar:

4.1 Patrones identificados

Personaje	Contraseña	Patrón detectado
Baltasar	Capitan2010Baltasar	NombreMascota + Año + NombrePropio
Rocío	toni2009mesaRocio	NombrePareja/Hijo + Año + Apellido + NombrePropio
Dolores	manuel1984Loli	NombrePareja + Año + Apodo
Fermín	lola2021!Fermin	NombreMascota + Año + Símbolo + NombrePropio
Isidoro	alberto2005RMadridista	Nombre? + Año + EquipoFútbol
Trinidad	MiaNube98Trini	NombresMascotas + AñoCorto + NombrePropio
Cristóbal	BrunoBetis77Cristo	NombreMascota + EquipoFútbol + AñoCorto + NombrePropio
Valvanera (yo)	Dobby2510Hufflepuff	NombreFandom + Fecha + CasaHogwarts

4.2 Elementos comunes en todas las contraseñas

1. **Referencia personal reconocible:** mascota, pareja, hijo, equipo de fútbol, fandom.
2. **Año o fecha numérica:** siempre presente (2009, 2010, 2021, 2005, 77, 98, 2510).
3. **Nombre propio o apodo al final:** en la mayoría de los casos.
4. **Uso esporádico de símbolos:** solo Fermín incluye !.
5. **Mayúsculas:** uso inconsistente (camelCase o PascalCase).
6. **Longitud media:** 15–20 caracteres (engañosamente largas pero predecibles).

4.3 Vulnerabilidad estructural

Un atacante que conozca:

- El nombre de mi mascota o fandom
- Una fecha significativa (cumpleaños, aniversario, adopción)
- Mi nombre o apodo

...puede generar un diccionario de 10–20 contraseñas candidatas con alta probabilidad de acierto. **No se necesita fuerza bruta**, solo OSINT y un bloc de notas.

5. ANÁLISIS DE MI PROPIA CONTRASEÑA

Contraseña: Dobby2510Hufflepuff

5.1 Fortalezas

- Longitud: 20 caracteres (aceptable).
- Incluye mezcla de mayúsculas y minúsculas.
- No contiene mi nombre ni apellido real directamente.

5.2 Debilidades

- **Totalmente predecible con OSINT:** si un atacante sabe que soy fan de Harry Potter, puede probar combinaciones de personajes, fechas y casas.
- Dobby y Hufflepuff son términos de diccionario de un universo fandom muy común. Existen listas de palabras específicas para Harry Potter circulando en Internet.
- 2510 es probablemente una fecha significativa (¿25 de octubre?). Si esta fecha aparece en mis redes sociales (ej. un post de cumpleaños, un tuit antiguo, un Instagram), el atacante la acota inmediatamente.
- **Sin símbolos especiales:** a diferencia de la de Fermín (lola2021!Fermin), la mía carece de !, #, \$, etc.
- **Sin números aleatorios:** 2510 no es aleatorio, es una fecha.

6. RIESGOS DE INGENIERÍA SOCIAL SOBRE MI PERSONAJE

Basándome en lo que mis compañeros han expuesto sobre mí en sus correos, un atacante podría construir un pretexto muy creíble:

6.1 Información que un atacante ya tiene sobre mí

Dato expuesto	Fuente	Uso malicioso potencial
Apodo: "Valva"	Correo de Fermín	Saludo personalizado en phishing: <i>"Hola Valva..."</i>
Afición al cosplay	Correo de Fermín	Suplantar una tienda o evento de cosplay para enviarme un enlace malicioso
Soy <i>potterhead</i>	Correo de Merche	Envío de phishing temático: <i>"Consigue entradas exclusivas para Harry Potter World..."</i>
Mascota/alias: Dobby	Correo de Fermín + mi contraseña	Referencia emocional en pretextos
Streaming en Twitch	Correo de Yaiza	Suplantar a Yaiza o a Twitch para robar credenciales

6.2 Escenario de ataque probable

Un atacante podría enviarme un correo fingiendo ser Fermín:

"Valva, para el photocall de Lola he encontrado esta web de disfraces de Dobby que está genial. ¿Me confirmas si te vale este? [enlace malicioso]"

La probabilidad de que yo haga clic es **alta** porque:

- El remitente usa mi apodo real.
- Conoce el nombre de la perra de Fermín (Lola).
- Sabe el contexto (photocall).
- Apela a mi fandom (Dobby).

7. MEDIDAS CORRECTORAS PROPUESTAS

En un entorno real, aplicaríamos las siguientes medidas inmediatamente:

7.1 Sobre mi cuenta personal (Valvanera Pinilla)

Medida	Prioridad	Justificación
Cambiar contraseña inmediatamente	CRÍTICA	Mi contraseña sigue un patrón predecible basado en OSINT. Debe ser sustituida por una frase de paso aleatoria.
Activar autenticación en dos factores (2FA)	CRÍTICA	Añade una capa de seguridad incluso si la contraseña es vulnerada.
Eliminar o privatizar publicaciones en redes sociales	ALTA	Cualquier referencia a Harry Potter, Dobby, Hufflepuff o cosplay reduce el radio de ataque OSINT.
No usar fechas personales en contraseñas	ALTA	El patrón 2510 es fácilmente vinculable a cumpleaños o aniversarios públicos.

7.2 Sobre el Ayuntamiento de Guarromán (medidas colectivas)

Medida	Prioridad	Destinatario	Justificación
Cambiar la contraseña WiFi inmediatamente	CRÍTICA	Departamento IT	La contraseña ea7xyzchiqui1995 fue enviada en texto plano a toda la organización. Debe considerarse comprometida .
Prohibir el envío de contraseñas por correo electrónico	CRÍTICA	Todo el personal	Los correos no están cifrados. Cualquier contraseña enviada por email debe considerarse expuesta.
Obligar a Antolín a cambiar todas sus contraseñas	CRÍTICA	Antolín (funcionario 7)	Él mismo confiesa reutilizar la misma contraseña en todos sus servicios.
Establecer una política de contraseñas robustas	ALTA	Todo el personal	Todas las contraseñas analizadas siguen el mismo patrón predecible (mascota + año + nombre).
Formación en ingeniería social y phishing	ALTA	Todo el personal	Los correos contienen información personal detallada que facilita ataques dirigidos.
Cifrar correos sensibles o usar canal interno seguro	MEDIA	Departamento IT	Las convocatorias de pleno con fechas, horas y asistentes no deberían circular en texto plano.
Limpiar metadatos de documentos públicos	MEDIA	Departamento IT	Si el ayuntamiento publica PDFs, deben eliminarse metadatos de autor, software, etc.
Auditoría de redes sociales del personal	MEDIA	Todo el personal	Revisar qué información pública existe de cada empleado que pueda usarse en OSINT.

8. CONCLUSIÓN

El Ayuntamiento de Guarromán presenta vulnerabilidades sistémicas en la gestión de credenciales y en la exposición de información personal a través del correo electrónico corporativo. La contraseña WiFi ha sido distribuida en texto plano, las contraseñas personales siguen patrones predecibles basados en datos OSINT, y los propios correos contienen suficiente información personal como para construir ataques de spear phishing altamente efectivos.

En un entorno real, la prioridad inmediata sería:

1. Cambiar la contraseña WiFi y TODAS las contraseñas de Antolín.
2. Implementar 2FA en todas las cuentas corporativas.
3. Formar al personal en no compartir contraseñas ni datos personales por email.
4. Auditoría de redes sociales y limpieza de datos públicos.